

HAMZEH EMREISH

Westchester, NY | (914) 335-5761 | Email: hamzehemreish37@gmail.com GitHub: github.com/sh4faq
LinkedIn: <https://www.linkedin.com/in/hamzeh-emreish/> Portfolio: hamzehemreish.netlify.app

EDUCATION

CUNY-Lehman College | Bronx, NY | B.S. Computer Science | Expected May 2026 | GPA: 3.4
Coursework: Data Structures, Full Stack Web Dev, Discrete Math, AI/ML, Robotics

EXPERIENCE

Bug Bounty Hunter *HackerOne / Bugcrowd / Intigriti* — Jan 2024 – Present

- Discovered a **Critical (CVSS 9.1)** parser allowlist bypass in a monitoring & observability platform's SQL expression engine (Intigriti); the fix for CVE-2026-27876 left 4 of 5 SetOp AST fields skipped by vitess walkSubtree unguarded, enabling Local File Inclusion via `load_file()` inside an ORDER BY clause. Same primitive class as CVE-2024-9264. Triaged as duplicate.
- Identified **High-severity** email injection on a crypto platform's Frappe-based contact form endpoint (HackerOne); the sender parameter is used as the email recipient rather than the sender address, enabling attacker-controlled outbound mail from the platform's legitimate domain to arbitrary recipients with full SPF/DKIM/DMARC alignment and no rate limit. Working end-to-end PoC with chained phishing payload; submitted, awaiting triage.
- Discovered a **High-severity (CVSS 8.6)** SSRF in a cloud infrastructure provider's GenAI Knowledge Base web crawler (Intigriti); HTTP 302 redirect bypass of hostname deny-list and IP resolution check reaches 169.254.169.254 cloud metadata service and internal infrastructure. Submitted May 14, 2026; awaiting triage.
- Found admin user enumeration on a crypto platform via Cognito ForgotPassword API (**High, CVSS 7.5**) on HackerOne; unauthenticated GraphQL query leaks the admin client_id, and Cognito's ForgotPassword endpoint returns distinct responses for valid versus invalid usernames (CodeDeliveryDetails vs UserNotFoundException), enabling admin email enumeration with first-letter leak. Patched shortly after testing; triaged as duplicate.
- Reported OAuth token exposure on a fitness tracking platform's API via Bugcrowd; access tokens embedded in window.__STATE__ on the public OAuth page enabled authentication bypass with confirmed account modification (PUT to a user resource returned HTTP 200, first_name modified) and mass user enumeration across IDs 1 through 231M+ via email, name, and query searches without rate limiting. Program ruled the modified account a test user and classified **P5/Informational**.
- Discovered hardcoded production API credentials (**CWE-798, CWE-522**) in a publicly-accessible JavaScript config on a domain registry's domain-suggestion product (Bugcrowd), granting unauthenticated access to all seven backend API endpoints. Triaged as duplicate of an earlier report (April 2025) with restricted key scope.
- Identified unauthenticated mail relay vulnerability (**Medium severity, triaged valid**) enabling email spoofing with valid DKIM/SPF signatures; provided CVSS analysis and remediation guidance.

Equinox - Manager on Duty (MOD) | Scarsdale, NY — Nov 2023 – Present

Promoted from Front Desk Associate; previously at Mamaroneck. Flagship rotations at Hudson Yards and Printing House.

- Contribute to strategy meetings with the General Manager, Regional Training Manager, and Facility Manager on member retention, personal training conversion, facility quality, and staff performance.
- Rebuilt front desk schedule and shift structure; closed a \$1,500 labor budget overrun and brought it to zero within three months.
- Run point on in-house tech for the club (BitLocker recovery, Windows blue screens, POS configuration, audio system faults, member-facing hardware); diagnose first, escalate to the vendor only when a part has genuinely failed.
- Daily club walkthroughs surface cleanliness and equipment risk; tag failing gear Out of Service and power-down treadmills at the source. Caught a member accessing the club on someone else's account for nearly a month from a photo-ID mismatch the desk had missed; escalated to GM, who verified and took action.
- Coach the front desk team on luxury-club engagement standards (phones off the desk, iPad-only check-in, security verification, greeting every member like a guest). Trained and onboarded 10+ team members; cross-trained in Pro Shop. CPR/AED certified.

Yonkers Car Wash — Website & Management System | 975 Midland Ave, Yonkers, NY — May 2025 – Present

- Developed and supported the **full-stack membership and billing website**, integrating member management, customer inquiries, and remote monitoring of car-wash systems via RDP/VNC through Tailscale.
 - Managed **ICS infrastructure**, database, billing automation; increased renewals 35%.
 - Supervised and **trained a 15-person team**, monitored cash registers and site operations remotely, and quickly mastered troubleshooting across all car wash systems.
-

PROJECTS AND ENGAGEMENTS

- **MCP Kali Server (Dec 2024)**: Contributed to open-source pentesting framework (PR #5 merged to TriV3/MCP-Kali-Server); added 12 recon tools (subfinder, nuclei, httpx, arjun, fierce, byp4xx, subzy, assetfinder, waybackurls, Shodan), SSH session management with file transfer, and reverse shell handlers. **GitHub**: github.com/TriV3/MCP-Kali-Server/pull/5
 - **Burp Suite Automation API (Nov 2024)**: Developed a Python extension exposing Burp Suite control via REST API for automated AI security testing. **GitHub**: github.com/sh4faq/burp-suite-api
 - **Flash MMO Protocol RE (Jan 2025)**: Analyzed multiplayer game security through network interception (Wireshark), memory inspection (Cheat Engine), SWF decompilation (JPEXS → ActionScript source), and binary analysis (Ghidra for DLL inspection); reverse-engineered SmartFoxServer XML/CDATA/JSON protocol; identified client-side anti-cheat bypass (MD5 + hardcoded salt); documented Electron + Pepper Flash architecture
 - **Game Asset Reverse Engineering Toolkit (Dec 2024)**: Reverse-engineered (Red Alert 2) VXL/HVA/MIX binary formats ; created Blender addon for 3D-to-voxel export.
 - **CodePath Blue Team (Oct 2024)**: NGINX rate-limiting, SNORT IDS, Splunk/Wireshark analysis.
 - **Full-Stack Merchant System (Nov 2024)**: Deployed PERN stack app with CRUD, search/sort, dark mode. Live: full-stack-pern-app.vercel.app
-

CERTIFICATIONS

- Anthropic Cyber Verification Program (CVP) — Approved May 14, 2026 for dual-use security research (vulnerability exploitation, offensive security tooling)
 - CompTIA Security+ SY0-701 — *Accomplished July 29, 2024*
 - Google Cybersecurity Certificate — *Accomplished Aug 5, 2024*
 - CodePath: Intermediate Cybersecurity & Python Programming — *Accomplished Oct 15, 2024*
-

TECHNICAL SKILLS

- **Security Tools & Testing**: Burp Suite, SNORT, Splunk, Wireshark, Nmap, Nikto, FFUF, gobuster, subfinder, Ghidra
- **Programming & Scripting**: Python, JavaScript, Bash, Java; REST API development; automation scripts for security testing
- **Web Development**: React, Node.js, Express.js, PostgreSQL, HTML/CSS, Vite; full-stack application deployment
- **Networking & Infrastructure**: TCP/IP, DNS, Active Directory, Group Policy, RDP/VNC, SSH, Tailscale; remote monitoring and system administration
- **Virtualization & Containers**: Proxmox, Docker, VMware, VirtualBox, Hyper-V, VPS
- **Reverse Engineering**: Ghidra + Cheat engine, Binary/hex analysis, proprietary file format documentation, struct-based parsing, Blender Python API